

Vulnerabilities & Threats that Matter

August 2022

Top 5 Takeaways

#1

Cisco was breached by conducting a **social engineering attack** on an **employee** by three threat actors namely **UNC2447**, **Lapsus\$**, and **Yanluowang ransomware gang**.

#2

VMware and SysAid, which were impacted by Log4j, were still exploited by LockBit 3.0 and MuddyWater, respectively.

#3

Ransomware attacks continued to increase, with **Industrial Spy**, **LockBit**, **Cuba**, **BlueSky**, **Zeppelin**, **BianLian**, and **Karakurt** targeting approximately **100** victims.

#4

This month also saw **four zero-day** vulnerabilities resolved by major corporations such as **Microsoft (CVE-2022-34713)**, **Google (CVE-2022-2856)**, and **Apple (CVE-2022-32893, CVE-2022-32894)**.

#5

There was a significant increase in the number of spearphishing campaigns conducted by RATs (**Manjusaka**, **Woody RAT**), banking trojans (**Grandoreiro**), and a Crypter (**DarkTortilla**)

Vulnerabilities of the Month	Threat Actors of the Month	Malware of the Month	Top Targeted Countries	Top Targeted Industries	Common MITRE ATT&CK TTPs
					
46	10	10	USA Russia UK Turkey Germany	Financial Healthcare Technology Telecommunication	130

Detailed Report

⚙ Vulnerabilities of the Month

VENDOR	CVE	PATCH DETAILS
	CVE-2022-31656 CVE-2022-31657 CVE-2022-31658 CVE-2022-31659 CVE-2022-31660 CVE-2022-31661 CVE-2022-31662 CVE-2022-31663 CVE-2022-31664 CVE-2022-31665 CVE-2021-44228	https://kb.vmware.com/s/article/89096 https://www.vmware.com/security/advisories/VMSA-2021-0028.html
	CVE-2022-30190* CVE-2022-21980 CVE-2022-24477 CVE-2022-24516 CVE-2022-30134 CVE-2022-34691 CVE-2022-34713* CVE-2022-35743 CVE-2022-35755 CVE-2022-35793 CVE-2022-35804 CVE-2022-24521* CVE-2020-1472 CVE-2020-0796 CVE-2021-1732*	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30190 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-21980 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-24477 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-24516 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30134 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34691 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-34713 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35743 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35755 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35793 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-35804 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-24521 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2020-1472 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2020-0796 https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-1732
	CVE-2022-27924 CVE-2022-27925 CVE-2022-37042 CVE-2022-24682	https://wiki.zimbra.com/wiki/Security_Center
	CVE-2022-30333	https://www.rarlab.com/rar/rarlinux-x32-612.tar.gz
	CVE-2022-0028	Upgrade to Palo Alto PAN-OS versions above 10.2.2-h2, 10.1.6-h6, 10.0.11-h1, 9.1.14-h4, 9.0.16-h3, 8.1.23-h1

VENDOR	CVE	PATCH DETAILS
	CVE-2022-2852 CVE-2022-2853 CVE-2022-2854 CVE-2022-2855 CVE-2022-2856* CVE-2022-2857 CVE-2022-2858 CVE-2022-2859 CVE-2022-2860 CVE-2022-2861	Update to Google Chrome version 104.0.5112.101 for Mac and Linux and 104.0.5112.102/101 for Windows https://www.google.com/intl/en/chrome/?standalone=1
	CVE-2022-32893* CVE-2022-32894*	Upgrade to macOS version 12.5.1
	CVE-2022-36804	https://confluence.atlassian.com/bitbucketserver/bitbucket-server-and-data-center-advisory-2022-08-24-1155489835.html
	CVE-2022-2884	Update GitLab Community Edition and Enterprise Edition to versions 15.3.1, 15.2.3, and 15.1.5
	CVE-2021-44228* CVE-2021-45046	https://www.sysaid.com/security-compliance/important-update-regarding-apache-log4j https://www.sysaid.com/product/on-premises/latest-release

*zero-day vulnerability

Threat Actors of the Month

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Yanluowang ransomware Gang 	China	Telecommunications, Professional Services, Retail	USA, Brazil, Turkey
	MOTIVE		
	Financial gain		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 LockBit Gang 	Unknown	Automotive, Aviation, Biotechnology, Chemicals, Construction & Engineering, Consumer, Defense, Distributors, Education, Electrical, Energy, Family Services, Financial, Food Products, Healthcare, Hotels, Insurance, IT, Machinery, Marine, Media, Metals & Mining, Oil and Gas, Pharmaceuticals, Professional Services, Real Estate, Retail, Telecommunication, Transportation, Utilities	Argentina, Australia, Austria, Bahrain, Belgium, Bosnia and Herzegovina, Brazil, Bulgaria, Canada, Cayman Islands, Chile, China, Cyprus, Czech Republic, Denmark, Ecuador, Finland, France, Germany, Hong Kong, Hungary, India, Indonesia, Iran, Ireland, Isle of Man, Italy, Japan, Kuwait, Lebanon, Malaysia, Mauritius, Mexico, Netherlands, New Zealand, Nicaragua, Norway, Oman, Peru, Poland, Portugal, Puerto Rico, Qatar, Romania, Saudi Arabia, Senegal, Singapore, South Africa, Spain, Sweden, Switzerland, Taiwan, Tanzania, Thailand, Turkey, United Arab Emirates, United Kingdom, United States, Vietnam, Ukraine
	MOTIVE		
	Financial Gain		
	CVEs		
	CVE-2021-44228		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 UNC2447 (Hello Kitty/ FiveHands) 	Unknown	Finance, Telecommunication	Europe and North America
	MOTIVE		
	Financial gain		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 UNC3890 	Iran	Energy, Airline, Transportation, Government and Healthcare	Israel
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Lapsus\$ (DEV-0537) 	Brazil	Telecommunication, Technology, Higher education, gaming and government organizations	Brazil, Portugal, USA
	MOTIVE		
	Data theft and Destruction		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 APT-C-35 (Operation Hangover, Appin, Donot, VICEROY TIGER and SectorE02) 	India	Financial, Government, Media, NGO, Technology, Telecommunications, Embassies and Defense	Afghanistan, Australia, Canada, China, India, Iran, Norway, Oman, Pakistan, Russia, Saudi Arabia, Singapore, Taiwan, Turkey, United Arab Emirates, United Kingdom and United States
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 MuddyWater (Seedworm, TEMP.Zagros, Static Kitten, Mercury, TA450, Cobalt Ulster, ATK 51, T-APT-14, ITG17) 	MOTIVE	Defense, Education, Energy, Financial, Food and Agriculture, Gaming, Government, Healthcare, High- Tech, IT, Media, NGOs, Oil and gas, Telecommunications, Transportation, Aerospace	Afghanistan, Armenia, Austria, Azerbaijan, Bahrain, Belarus, Egypt, Georgia, India, Iran, Iraq, Israel, Jordan, Malta Kuwait, Laos, Lebanon, Mali, Netherlands, Oman, Pakistan, Russia, Saudi Arabia, Tajikistan, Thailand, Tunisia, Turkmenistan Turkey, UAE, Ukraine, USA
	Iran		
	Information theft and espionage		
	CVEs		
	CVE-2021-44228 CVE-2021-45046		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 CHARMING KITTEN (Newscaster, Parastoo, APT35, Phosphorus, Magic Hound, Cobalt Illusion, Cobalt Mirage, TEMP.Beanie, Timberworm, Tarh Andishan, TA453, TunnelVision, UNC788) 	MOTIVE	Aerospace, Education, Energy, Financial, Government, Healthcare, Mass media, NGO, IT Oil and Gas, Pharmaceuticals, Defense, Technology and Telecommunications	Afghanistan, Canada, Egypt, Germany, Iran, Iraq, Israel, Jordan,Kuwait, Morocco, Pakistan, Saudi Arabia,Spain, Syria,Turkey, UAE,United Kingdom, USA, Venezuela and Yemen
	Iran		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 <u>Kimsuky (Velvet Chollima, Thallium, Cerium, Black Banshee, ITG16, TA406)</u> 	North Korea	Cryptocurrency, Defense, Education, Energy, Government, Healthcare, Media NGO, Pharmaceuticals, Policy Institute	France, Japan, Russia, South Africa, South Korea, United Kingdom, United States
	MOTIVE		
	Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 <u>Karakurt</u> 	Unknown	Energy, Entertainment, Healthcare, Hospitality, Industrial, Manufacturing, Retail and Technology	USA, Hungary, Belarus, Austria, Serbia, Switzerland, Germany, Holy See, Andorra, Bulgaria, UK, France, Montenegro, Luxembourg, Italy, Denmark, Finland, Slovakia, Norway, Ireland, Spain, Malta, Ukraine, Croatia, Moldova, Monaco, Liechtenstein, Poland Iceland, San Marino, Bosnia and Herzegovina, Albania, Lithuania, North Macedonia, Slovenia, Romania, Latvia, Netherlands, Russia, Estonia, Belgium, Czech Republic(Czechia), Greece, Portugal Sweden, South Africa, Canada, Japan, Australia, China, Hong Kong, Turkey, and India
	MOTIVE		
	Financial gain		
	CVEs		



Malware of the Month

NAME	OVERVIEW	TYPE	DELIVERY METHOD
<u>Manjusaka</u> 	Manjusaka has an ELF binary written in GoLang, while the implants are written in the Rust programming language. It consists of a variety of capabilities that can be used to control the infected endpoint, including executing arbitrary commands.	Remote Access Trojan(RAT)	Malicious documents
<u>Woody RAT</u> 	Woody RAT can write arbitrary files to the machine, and run additional malware, delete files, enumerate directories, capture screenshots, and gather a list of running processes.	Remote Access Trojan(RAT)	Microsoft Office documents vulnerable to CVE-2022-30190
<u>ROADSWEEP</u> 	The ROADSWEET ransomware tool enumerates files on the device and encrypts the content in blocks using RC4. It has a couple of embedded scripts that are used to either run commands or delete the traces of malware from the victim's device as a defensive evasion tactic.	Ransomware	Unknown
<u>Industrial Spy</u> 	Industrial Spy has two executables. The first binary samples are spread via cracks, adware, and in-the-wild loaders and stealers and have no disruptive action. In contrast, the second executable encrypts files on the targeted machine.	Ransomware	Unknown
<u>Cuba</u> 	The ransomware encrypts the file with ChaCha from the open source WolfSSL repository and RSA for key encryption. When a file is successfully encrypted, the extension .cuba is added to the filename.	Ransomware	Malicious attachments
<u>Zeppelin</u> 	Zeppelin is deployed as a.dll or.exe file or bundled in a PowerShell loader. Before encryption, adversaries exfiltrate sensitive corporate files to sell or disclose if the victim does not pay the ransom in Bitcoins.	Ransomware	Through RDP exploitation, SonicWall firewall exploits, or phishing tactics

NAME	OVERVIEW	TYPE	DELIVERY METHOD
<u>BlueSky</u> 	BlueSky ransomware is initially dropped via PowerShell script start.ps1 onto the intended system. Following the extraction, another PowerShell script named stage.ps1 downloads a bunch of payloads based on the victim's system privileges. After gaining enhanced privileges, stage.ps1 downloads the BlueSky ransomware payload and stores it locally to the filesystem as javaw.exe, attempting to impersonate a legitimate Windows application.	Ransomware	Unknown
<u>BianLian</u> 	BianLian, a new ransomware strain written in Go. It uses multiple APIs to encrypt data, copy files, and identify drivers. It adds “.bianlian” extension to all the files before slipping a ransomware note under the file name "Look at this instruction.txt."	Ransomware	Unknown
<u>Grandoreiro</u> 	Grandoreiro is a campaign that has been active since at least 2016. The trojan is built in Delphi and employs techniques such as binary padding to inflate binaries, Captcha implementation for sandbox evasion, and command-and-control (C&C).	Banking Trojan	Spear-phishing emails
<u>DarkTortilla</u> 	DarkTortilla is a sophisticated and highly configurable .NET-based crypter that has been active since at least August 2015. The malware is popular for the deployment of remote access trojans (RATs), targeted payloads, and information stealers like RedLine, AgentTesla, NanoCore, Metasploit, Cobalt Strike, and AsyncRat.	Crypter	Malicious spam (malspam)

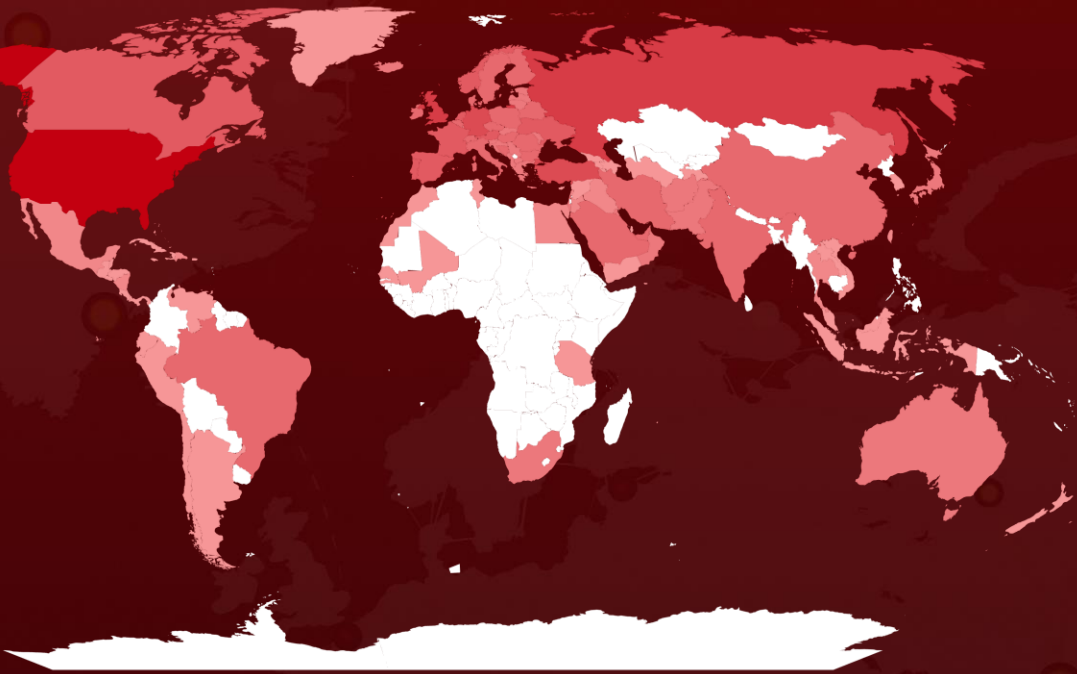


Targeted Countries

Most



Least



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Targeted Industries



Common MITRE ATT&CK TTPs

TA0043: Reconnaissance	TA0042: Resource Development	TA0001: Initial Access	TA0002: Execution	TA0003: Persistence	TA0004: Privilege Escalation	TA0005: Defense Evasion
T1589: Gather Victim Identity Information	T1586: Compromise Accounts	T1189: Drive-by Compromise	T1059: Command and Scripting Interpreter	T1098: Account Manipulation	T1134: Access Token Manipulation	T1134: Access Token Manipulation
T1589.001: Credentials	T1586.002: Email Accounts	T1190: Exploit Public-Facing Application	T1059.001: PowerShell	T1098.005: Device Registration	T1547: Boot or Logon Autostart Execution	T1622: Debugger Evasion
T1589.002: Email Addresses	T1587: Develop Capabilities	T1133: External Remote Services	T1059.005: Visual Basic	T1547: Boot or Logon Autostart Execution	T1547.001: Registry Run Keys / Startup Folder	T1140: Deobfuscate/Decode Files or Information
	T1587.001: Malware	T1566: Phishing	T1059.003: Windows Command Shell	T1547.001: Registry Run Keys / Startup Folder	T1543: Create or Modify System Process	T1574: Hijack Execution Flow
	T1588: Obtain Capabilities	T1566.001: Spearphishing Attachment	T1203: Exploitation for Client Execution	T1136: Create Account	T1543.003: Windows Service	T1574.002: DLL Side-Loading
	T1588.002: Tool	T1566.002: Spearphishing Link	T1106: Native API	T1136.001: Local Account	T1546: Event Triggered Execution	T1562: Impair Defenses
	T1588.006: Vulnerabilities	T1091: Replication Through Removable Media	T1053: Scheduled Task/Job	T1543: Create or Modify System Process	T1546.012: Image File Execution Options Injection	T1562.004: Disable or Modify System Firewall
	T1608: Stage Capabilities	T1195: Supply Chain Compromise	T1053.005: Scheduled Task	T1543.003: Windows Service	T1068: Exploitation for Privilege Escalation	T1070: Indicator Removal on Host
	T1608.004: Drive-by Target	T1199: Trusted Relationship	T1072: Software Deployment Tools	T1546: Event Triggered Execution	T1574: Hijack Execution Flow	T1070.001: Clear Windows Event Logs
		T1078: Valid Accounts	T1569: System Services	T1546.012: Image File Execution Options Injection	T1574.002: DLL Side-Loading	T1070.004: File Deletion
			T1569.002: Service Execution	T1133: External Remote Services	T1055: Process Injection	T1070.006: Timestomp
			T1204: User Execution	T1574: Hijack Execution Flow	T1055.012: Process Hollowing	T1036: Masquerading
			T1204.002: Malicious File	T1574.002: DLL Side-Loading	T1053: Scheduled Task/Job	T1036.005: Match Legitimate Name or Location
			T1204.001: Malicious Link	T1556: Modify Authentication Process	T1053.005: Scheduled Task	T1556: Modify Authentication Process
				T1053: Scheduled Task/Job	T1078: Valid Accounts	T1112: Modify Registry
				T1053.005: Scheduled Task		T1027: Obfuscated Files or Information
				T1505: Server Software Component		T1027.002: Software Packing
				T1078: Valid Accounts		T1055: Process Injection
						T1055.012: Process Hollowing
						T1553: Subvert Trust Controls
						T1218: System Binary Proxy Execution
						T1221: Template Injection
						T1127: Trusted Developer Utilities Proxy Execution
						T1078: Valid Accounts
						T1497: Virtualization/Sandbox Evasion
						T1497.001: System Checks

TA0006: Credential Access	TA0007: Discovery	TA0008: Lateral Movement	TA0009: Collection	TA0011: Command and Control	TA0010: Exfiltration	TA0040: Impact
T1555: Credentials from Password Stores	T1087: Account Discovery	T1210: Exploitation of Remote Services	T1560: Archive Collected Data	T1071: Application Layer Protocol	T1020: Automated Exfiltration	T1485: Data Destruction
T1555.003: Credentials from Web Browsers	T1622: Debugger Evasion	T1021: Remote Services	T1560.001: Archive via Utility	T1071.001: Web Protocols	T1048: Exfiltration Over Alternative Protocol	T1486: Data Encrypted for Impact
T1056: Input Capture	T1083: File and Directory Discovery	T1091: Replication Through Removable Media	T1115: Clipboard Data	T1573: Encrypted Channel	T1041: Exfiltration Over C2 Channel	T1490: Inhibit System Recovery
T1056.001: Keylogging	T1135: Network Share Discovery	T1072: Software Deployment Tools	T1005: Data from Local System	T1573.002: Asymmetric Cryptography	T1567: Exfiltration Over Web Service	T1498: Network Denial of Service
T1056.003: Web Portal Capture	T1120: Peripheral Device Discovery		T1114: Email Collection	T1105: Ingress Tool Transfer	T1567.002: Exfiltration to Cloud Storage	T1498.002: Reflection Amplification
T1556: Modify Authentication Process	T1057: Process Discovery		T1056: Input Capture	T1104: Multi-Stage Channels		T1496: Resource Hijacking
T1621: Multi-Factor Authentication Request Generation	T1012: Query Registry		T1056.001: Keylogging	T1095: Non-Application Layer Protocol		T1489: Service Stop
T1003: OS Credential Dumping	T1518: Software Discovery		T1056.003: Web Portal Capture	T1572: Protocol Tunneling		
T1003.003: NTDS	T1518.001: Security Software Discovery		T1113: Screen Capture	T1090: Proxy		
	T1082: System Information Discovery			T1090.003: Multi-hop Proxy		
	T1016: System Network Configuration Discovery			T1219: Remote Access Software		
	T1049: System Network Connections Discovery			T1102: Web Service		
	T1033: System Owner/User Discovery			T1102.002: Bidirectional Communication		
	T1007: System Service Discovery					
	T1497: Virtualization/Sandbox Evasion					
	T1497.001: System Checks					

🕸 Threat Advisories (August 2022)

MONDAY		TUESDAY		WEDNESDAY		THURSDAY		FRIDAY		SATURDAY		SUNDAY	
1		2		3		4		5		6		7	
						 							
8		9		10		11		12		13		14	
						 		 					
15		16		17		18		19		20		21	
						 							
22		23		24		25		26		27		28	
		 		 		 		 					
29		30		31		Click on any of the icons to get directed to the advisory  Red Vulnerability Report  Amber Vulnerability Report  Red Attack Report  Amber Attack Report							
		 											

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

September 16, 2022 • 7:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com